

시정 및 주의요구

제 목 정보시스템 사용자계정 관리 불철저

소 관 부 서(기관) □□□□처

조 치 부 서(기관) □□□□처

내 용

1. 업무 개요

공사(公社)는 행정업무의 전자적 처리를 위해 내·외부 경영정보시스템을 운영하고 있으며 □□□□처는 「직제 규정 시행세칙」 제6조(업무분장)에 따라 경영정보시스템 운영 및 관리 업무를 담당하고 있다.

2. 판단 기준

국가정보원 「국가 정보보안 기본지침」 제75조(계정관리)에 따르면 정보시스템 관리자는 개별사용자의 보직변경, 퇴직 등 변동사항이 발생할 경우 신속히 사용자계정을 삭제하거나 부여된 접근권한을 회수하도록 되어 있다.

그리고 공사 「정보보안관리 규정」 제21조(사용자계정 관리)에 따르면 정보시스템 관리자는 매월 1회 이상 사용자계정 부여 및 관리 상태를 점검하도록 되어 있다.

따라서 □□□□처는 매월 정보시스템별로 사용자계정을 점검하여야 하고 인사변동이 있을 경우에는 즉시 사용자계정을 삭제하거나 부여된 접근권한을 회수하여 사용자별로 접근권한이 적정하게 부여되도록 관리하여야 한다.

3. 감사결과 확인된 문제

그런데 2022.8.26. 감사일 현재 그룹웨어(KOIN)의 사용자계정별 비공개문서, 공개열람 제한문서에 대한 접근권한 보유 내역을 점검한 결과 인사발령으로 보직이 변경되었음에도 불구하고 접근권한을 보유하고 있는 직원이 있었다.

비공개문서는 감사사항, 계약, 영업비밀정보 등 각 부서별 주요 업무사항이 포함되어 있고, 특히 공개열람제한문서는 직원의 고충처리, 채용관련 정보, 신고 및 소송관련 사항 등 업무관련 직원 외의 접근이 차단되어야 함에도 □□□□처는 사용자계정 점검을 소홀히 하여 전(前) 업무 담당자 등이 접근권한을 보유하고 있는 사실을 인지하지 못하고 있었다.

또한 □□□□처는 웹메일 사용자계정도 계정을 중복하여 발급하거나 퇴직자의 계정을 삭제 조치하지 않는 등 사용자계정 관리를 철저하게 하지 않았다.

관련부서(기관) 의견 □□□□처는 정보시스템 특성에 따라 시스템 담당자와는 별도로 책임자를 지정하여 권한 부여 및 회수를 판단·운영하여야 하고, 그룹웨어(KOIN)의 사용자계정별 비공개문서 등 접근권한 회수여부도 업무주관부서에서 수행하여야 하므로 정기점검을 통해 권한을 임의로 삭제할 수 없다는 의견을 제시하였다.

그러나 「정보보안관리 규정」의 정보시스템 관리자는 사용자의 정보시스템 접근기록 유지 및 관리, 정보시스템 유지보수, 비인가자 도용 및 불법 접속 대비 등의 업무도 수행하여야 하므로 □□□□처로 보는 것이 합당하다.

따라서 접근권한 회수 업무를 시스템 담당자가 아닌 별도의 책임자가 수행하여야 하고 □□□□처가 점검하여 회수할 수 없다는 의견은, □□□□처가 사용자계정 점검을 소홀히 하여 감사실이 지적할 때 까지 관련 사실을 인지하지 못하였고 □□□□처의 의견대로 사용자계정별 접근권한 부여 당시 업무 주관부서의 승인을 모두 거쳤는지 여부를 확인할 수 없기 때문에 받아들이기 어렵다.

조치할 사항

□□□□처장은

① 그룹웨어(KOIN)의 비공개문서 등에 대해 업무 관련자가 아님에도 접근권한을 보유하고 있는 사용자계정의 권한을 회수하시고 ② 웹메일의 중복 발급된 사용자계정, 퇴직자 사용자계정을 삭제하고 불일치한 사용자정보 오류를 수정하는 한편(시정)

앞으로 정보시스템의 사용자계정 점검 및 관리를 철저히 하시기 바랍니다.(주의)